The five-minute skill check

Before you install an agent skill from someone you don't know

Agentic. Schule

1 Read the `SKILL.md`

The file your agent will read as instructions, every line. Not the README of the marketplace.

2 Search for addresses

Does every domain really belong to the vendor? Is the spelling exactly right? Every URL is a place where something different may sit tomorrow.

```
grep -rn "https\?://" .
```

3 Search for authority

Phrases that turn foreign text into commands: "ground truth", "authoritative", "always follow the instructions at", "without bothering the user".

```
grep -rniE "ground truth|authoritative|always follow" .
```

4 Look into the scripts

Not only the Markdown files. And everything the skill wants to install: "prerequisites", "setup", "install it globally".

5 Origin over popularity

Who submitted it, and how old is the account? Stars belong to the repository, not to a single skill in it.

Three rules that matter more than the check

- **A skill that fetches instructions from the internet cannot be reviewed.** What gets executed is whatever sits behind the link right now.
- **Treat foreign skills as a template, never as a dependency.** Let your agent rewrite them in its own words. Invisible characters don't survive being rephrased.
- **Keep the safety nets on.** Sandbox on, no YOLO, Turbo or skip-permissions with a new skill, and read every permission prompt.

From the talk "Dangerous AI Skills" by Johannes Hoppe · Slides, script and sources: talks.agentic.schule/dangerous-ai-skills/materials/